

Latest SMB Vulnerabilities

One recent significant vulnerability that affected the SMB protocol was called [SMBGhost](#) with the [CVE-2020-0792](#). This vulnerability consisted of a compression mechanism of the version SMB v3.1.1 which made Windows 10 versions 1903 and later vulnerable to a denial of service by an unauthenticated attacker. The vulnerability allowed the attacker to gain remote code execution (RCE) on the target system.

We will not discuss the vulnerability in detail in this section, as a very in-depth explanation requires some understanding of network protocols and advanced knowledge of CPU, kernel, and exploit development. Instead, we will only focus on the attack concept. For more complicated exploits and vulnerabilities, the concept remains the same.

The Concept of the Attack

In simple terms, this is an [integer overflow](#) vulnerability in a function of an SMB driver that allows system crashes while accessing memory. An integer overflow results from a CPU attempting to generate a number that is outside the range of values for the allocated memory space. Arithmetic operations can always return unexpected values, resulting in an integer overflow. An integer overflow can occur when a programmer does not allow a negative number to occur. In this case, a variable performs an operation that results in a negative number, and the variable is returned as a positive number. This occurred because, at the time, the function lacked bounds checks to handle the size of the data sent in the SMB negotiation.

To learn more about buffer overflow techniques and vulnerabilities, check out the [Stack-Based Buffer Overflows on Windows x86](#) module. These go into detail on the basics of how the buffer can be exploited by the attacker.

The Concept of Attacks



Initiation of the Attack

This is when the cycle starts all over again, but this time to gain remote access to the target system.

Trigger Remote Code Execution

However, despite the vulnerability's complexity due to the buffer's manipulation, which we can see in the `main` function, the exploit nevertheless applies here.

SMB

 Attacking SMB

[Latest SMB Vulnerabilities](#)

SQL Databases

 Attacking SQL Databases

[Latest SQL Vulnerabilities](#)

RDP

 Attacking RDP

[Latest RDP Vulnerabilities](#)

DNS

 Attacking DNS

[Latest DNS Vulnerabilities](#)

SMTP

 Attacking Email Services

[Latest Email Service Vulnerabilities](#)

Skills Assessment

 Attacking Common Services - Easy

 Attacking Common Services - Medium

 Attacking Common Services - Hard

My Workstation

O F F L I N E